API SENTINEL

AI-Powered API Security & Intelligent Threat Detection Platform

Executive Summary: API Sentinel is an enterprise-grade cybersecurity web platform engineered to demonstrate how Artificial Intelligence and Machine Learning can be coupled with heuristic WAF rules to detect API vulnerabilities, thwart zero-day attacks, and execute automated mitigation in real time. Designed in the operational paradigm of a Security Operations Center (SOC), this document provides a complete technical walkthrough and illustrated user manual covering all dashboard capabilities, telemetry monitors, attack simulation labs, and machine learning models.

Platform Version:	v2.4.0-Enterprise-SOC	**Classification:**	Dual-Engine ML (RF + Isolation Forest)
Live Showcase Webpage:	https://brshirisha27-cloud.github.io/api-sentinel-ai-security/	**Local Server:**	http://127.0.0.1:5000
GitHub Repository:	https://github.com/brshirisha27-cloud/api-sentinel-ai-security	**Test Suite:**	8 / 8 Automated Tests Passed (100%)
Documentation Scope:	All 6 SOC Dashboard Options & Forensic Telemetry Screens	**Date of Issue:**	November 2026



Figure 1: Full-Spectrum SOC Command Dashboard with 360° Threat Radar, Real-Time Gradient Timeline, and Neon KPI Cards.

1. System Architecture & SOC Visual Hierarchy

API Sentinel operates on a three-tier defensive architecture that combines instantaneous deterministic heuristic filtering with supervised classification and unsupervised zero-day outlier detection. Incoming API calls pass through an ingestion pipeline where feature extraction computes behavioral metrics (burst rate, failed logins, payload danger index, status code, and response latency).

Accent / Color	Hex Code	Visual Purpose & Operational Meaning
Obsidian Navy	#050811	High-contrast primary canvas background minimizing visual fatigue during long monitoring shifts.
Electric Cyan	#00f0ff	Primary telemetry accent, healthy status badges, top laser scanlines, and throughput spline graphs.
Radiant Emerald	#00f59b	Safe verified traffic, 200 OK responses, compliant baseline requests, and resolved incidents.
Solar Amber	#ffb703	Suspicious traffic bursts, 4xx client errors, auth failures, and investigating alerts.
Crimson Laser	#ff2e63	Critical threats, automated WAF blocks, SQLi/BOLA attempts, and high-anomaly radar blips.

Composite Risk Score Formula:
Every incoming HTTP request is evaluated into a unified **Composite Risk Score (0–100)** based on weighted input factors: Risk = 0.40 × ML_Class_Score + 0.35 × Anomaly_Index + 0.25 × Heuristic_Penalty.

- **0 – 29 (Normal):** Passed immediately to backend application services.
- **30 – 69 (Suspicious):** Passed with forensic telemetry logging and security alert escalation.
- **70 – 100 (Critical Attack):** Terminated at the edge with HTTP 403 Forbidden or 429 Too Many Requests.

2. Option 1: SOC Command Dashboard

The **SOC Command Dashboard** provides security analysts with a holistic, single-pane-of-glass overview of all incoming API transactions, threat distribution categories, active radar tracking, and real-time operational KPIs.



Figure 2: Option 1 — SOC Command Dashboard with live radar blips, spline charts, and quick attack test bars.

Key Components & Operational Features:

- **Top Cyber Laser Scanline:** High-frequency animated linear gradient providing visual confirmation of an active, running ingestion pipeline.
- **Live Clock & UTC Synchronization:** Renders both local browser time and exact UTC wall-clock time for standardized multi-analyst timeline correlation.
- **Four Neon KPI Telemetry Cards:** Displays Total Requests processed (Cyan), Safe Verified Requests (Emerald), Suspicious Events (Amber), and Blocked Attacks (Crimson).
- **360° Threat Radar Scope HUD:** Emulates military air-defense radar with a rotating 360° radial sweep ray. Active threats are mapped as pulsing target blips plotted by severity.
- **Real-Time Traffic Timeline (Chart.js Spline):** Area spline chart with a cyan linear gradient showing throughput spikes and volumetric surges over 15 chronological intervals.
- **Threat Category Distribution (Doughnut Chart):** Categorizes identified threats into Authentication (Credential Stuffing), Injection (SQLi/XSS), Rate Limit DoS, and BOLA/IDOR.
- **Recent Alerts & Requests Telemetry Feeds:** Chronological micro-tables displaying the latest security incidents and raw HTTP transactions with HTTP method badges.

3. Option 2: API Traffic Telemetry & Packet Monitoring

The **API Traffic Telemetry** view provides deep, packet-level visibility into every individual HTTP call passing through the gateway. Analysts can monitor latency, payload sizes, status codes, and AI risk classifications in real time.

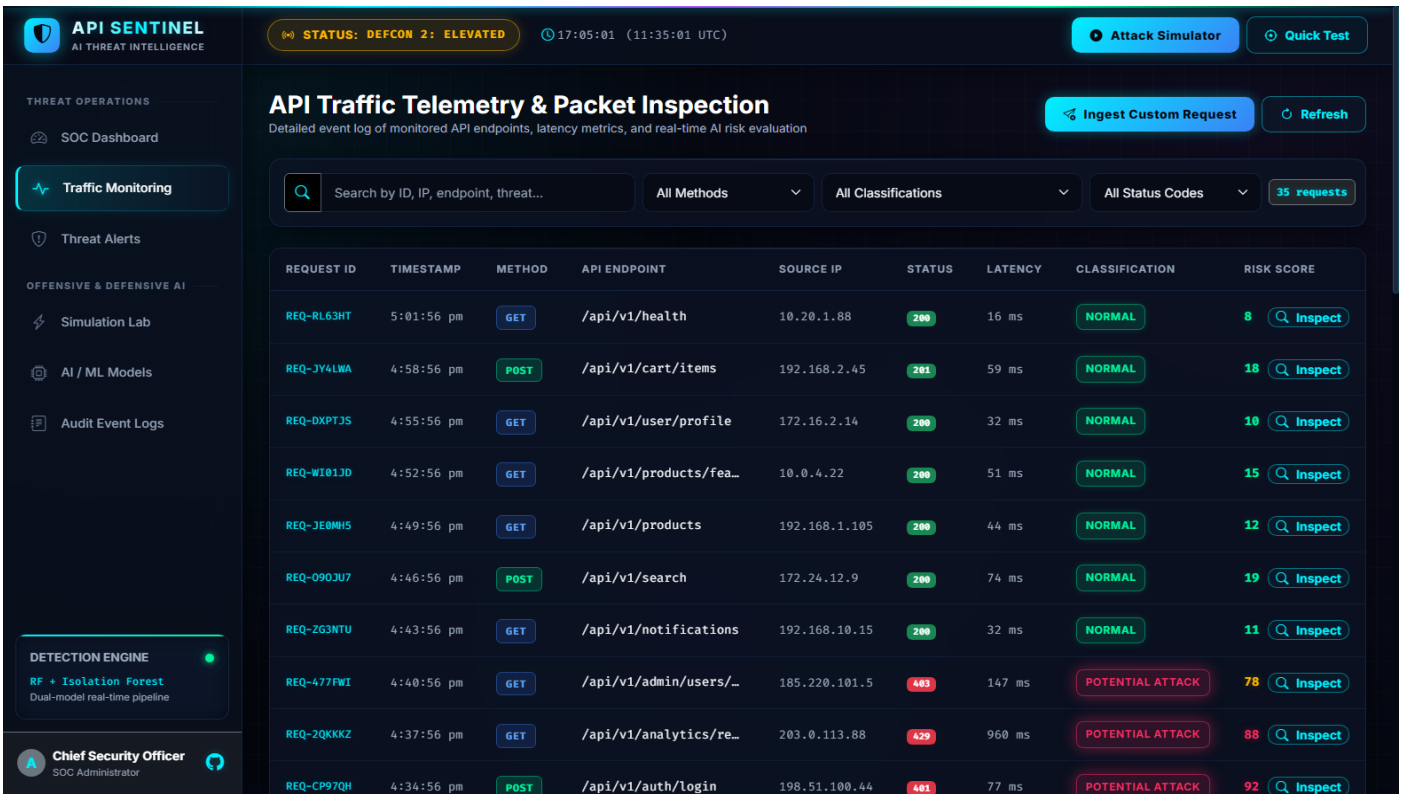


Figure 3: Option 2 — Real-time API Traffic Telemetry log with status filter pills and dynamic 0–100% risk meters.

Operational Telemetry Capabilities:

- **Full Transaction Audit:** Logs Request ID (REQ-XXXXXX), timestamp, HTTP Method (GET, POST, DELETE), Endpoint, Status Code, Latency in ms, Payload Size, and Client IP.
- **Instant Filter Pills:** Allows analysts to instantly isolate traffic by status: ALL, SAFE (200s), SUSPICIOUS (4xx), or BLOCKED (Attacks) without reloading the page.
- **Dynamic Risk Meter Bar:** Visual 0–100% progress meter color-coded by threat severity (Emerald for 0–29%, Solar Amber for 30–69%, Crimson for 70–100%).
- **One-Click Forensic Inspection:** Every table row includes an Inspect button that launches the Deep Packet Inspection Modal.

4. Deep Packet Inspection & Explainable AI (XAI) Modal

Clicking the **Inspect** button on any telemetry record launches the **Deep Packet Inspection Modal**, providing a comprehensive forensic dissection of the request headers, payload characteristics, ML scoring, and decision logic.

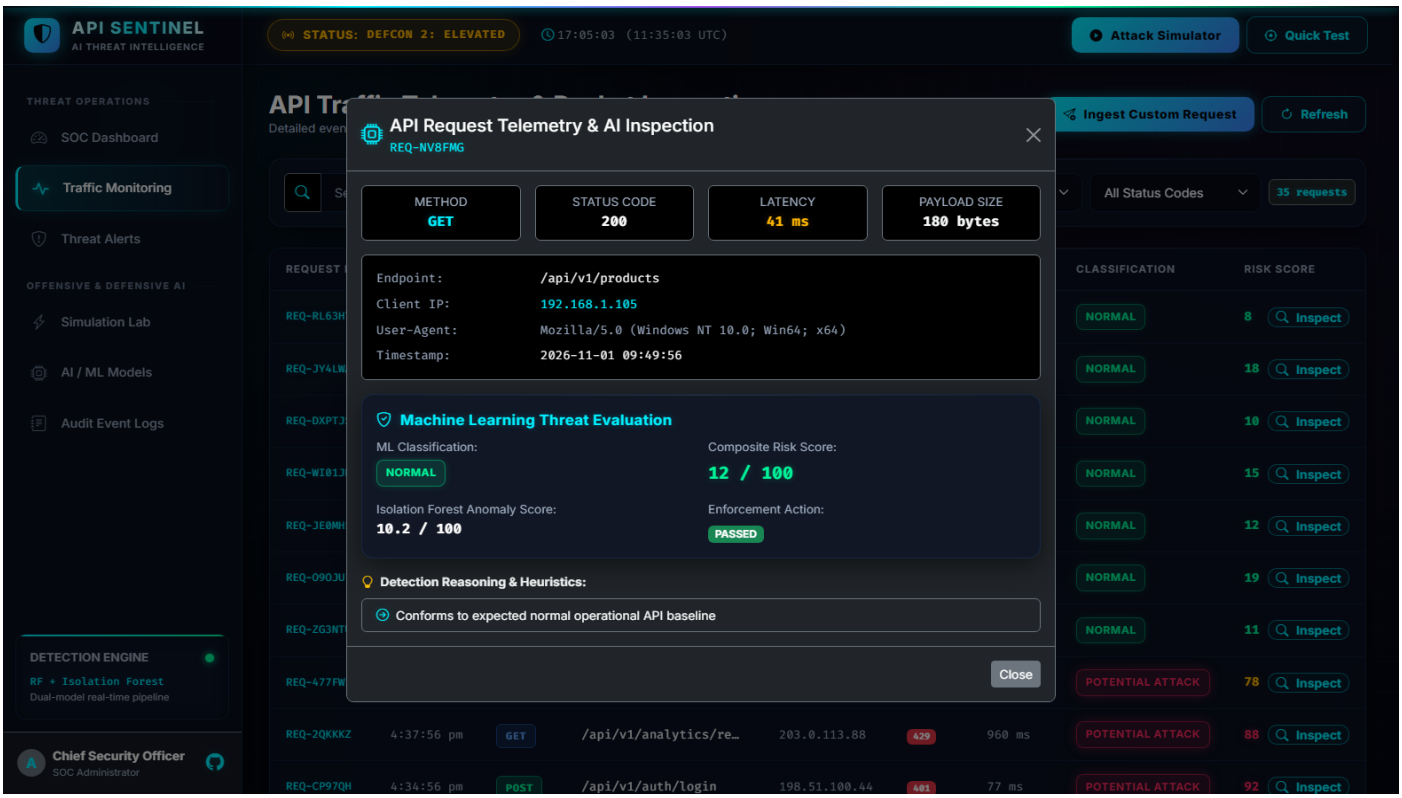


Figure 4: Forensic Deep Packet Inspection Modal with connection metadata, dual ML scores, and explainable rule reasoning.

Forensic Inspection Dissection:

- **Connection Header Cards:** Inspects HTTP Method, HTTP Status Code, Server Latency (ms), Payload Size (bytes), and User-Agent fingerprint.
- **Random Forest Classifier Decision:** Displays the categorical classification: Normal, Suspicious, or Potential Attack.
- **Isolation Forest Anomaly Score:** Displays the continuous anomaly index (0–100) indicating the degree of statistical deviation from baseline behavior.
- **Automated Enforcement Decision:** Displays whether the request was PASSED through to microservices or BLOCKED AT WAF.
- **Explainable AI (XAI) Rule Reasonings:** Lists plain-English rationales explaining why the packet was flagged (e.g. *Dangerous SQL injection union regex pattern; Extreme request frequency burst from single IP*).

5. Option 3: Security Incidents & Threat Alerts Triage

The **Threat Alerts** tab is the central incident response triage matrix where detected attacks are queued, categorized by severity, analyzed with forensic metadata, and transitioned through active triage stages.

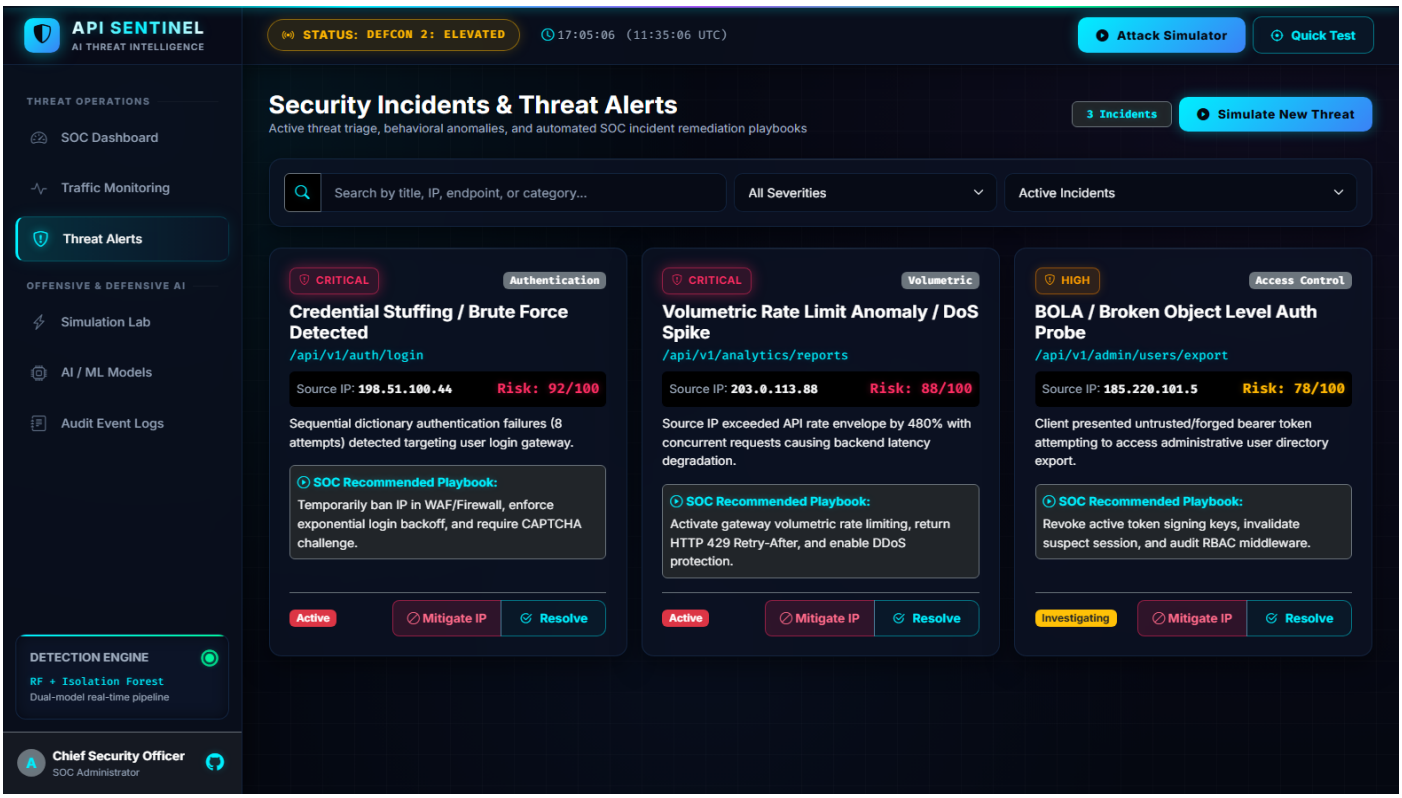


Figure 5: Option 3 — Threat Alerts Triage Matrix with risk scores, attacker forensics, and 3-stage incident actions.

Incident Triage Workflow & Features:

- **Severity Categorization:** Visual glowing badges categorize threats into CRITICAL (Risk 85–100), HIGH (Risk 70–84), and MEDIUM (Risk 50–69).
- **Attacker Forensics Metadata:** Displays affected endpoint, attacker source IP, target account, and first/last detected timestamps.
- **Prescriptive Mitigation Guidance:** Outlines actionable steps for the incident response team (e.g., *Block IP at edge WAF, inspect ORM queries, rotate compromised JWT secrets*).
- **Interactive Triage Handlers:**
  1. **Investigate:** Marks the incident as under active analyst review (Amber Investigating badge).
  2. **Mitigate:** Applies interim containment rules and moves status to Cyan Mitigated.
  3. **Resolve:** Confirms threat eradication and archives the incident as Emerald Resolved.

6. Option 4: Adversarial Attack Simulation Lab

The **Adversarial Attack Simulation Lab** is a controlled offensive security sandbox built directly into API Sentinel. It enables security engineers and evaluators to fire simulated cyber attacks against the defense engine and observe real-time detection reactions.

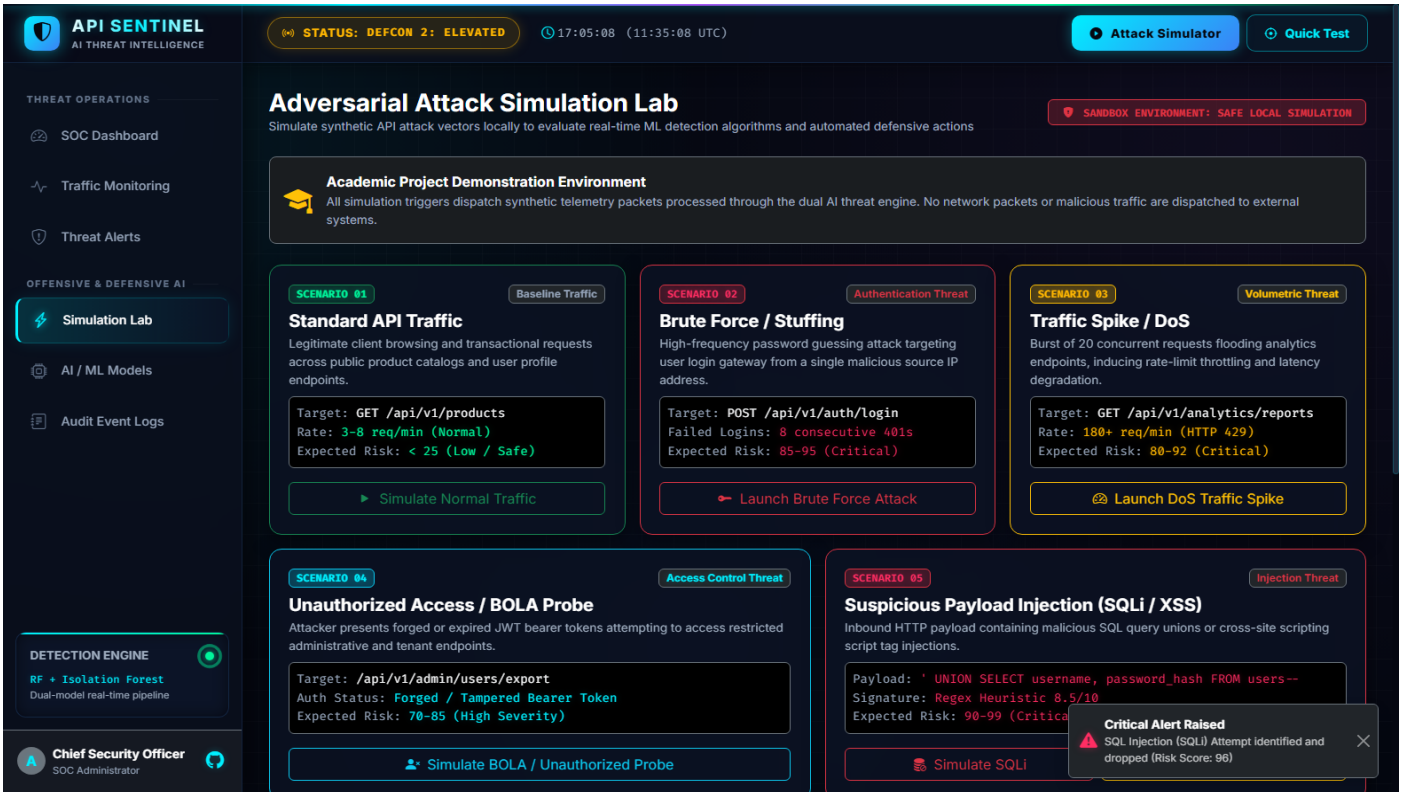


Figure 6: Option 4 — Adversarial Simulation Lab with 5 attack scenario triggers, custom payload builder, and live terminal console.

Simulated Cyber Attack Scenarios:

- **1. Normal User Flow:** Emulates benign user browsing (GET /api/v1/products) to verify low false-positive rates.
- **2. Credential Stuffing (Brute Force):** Dispatches 12 rapid failed authentication attempts (POST /api/v1/auth/login) testing account lockout defenses.
- **3. Volumetric DoS Spike:** Dispatches 25 rapid requests within 5 seconds to test automated rate-limiting thresholds (HTTP 429).
- **4. BOLA / IDOR Probing:** Simulates horizontal privilege escalation attempts targeting /api/v1/admin/users/export with forged JWT tokens.
- **5. SQLi & XSS Payload Injection:** Transmits malicious query strings ('; UNION SELECT username, password_hash FROM users--) testing WAF payload sanitizers.
- **Live Cyber Terminal Console:** Monospace terminal output streams real-time HTTP dispatch headers, ML classification outcomes, and defensive blocking actions.

7. Option 5: AI & Machine Learning Intelligence Engine

The **AI & ML Models** view provides a transparent, explainable view into the architecture, mathematical specifications, confusion matrix evaluations, and feature weights of the underlying machine learning models.

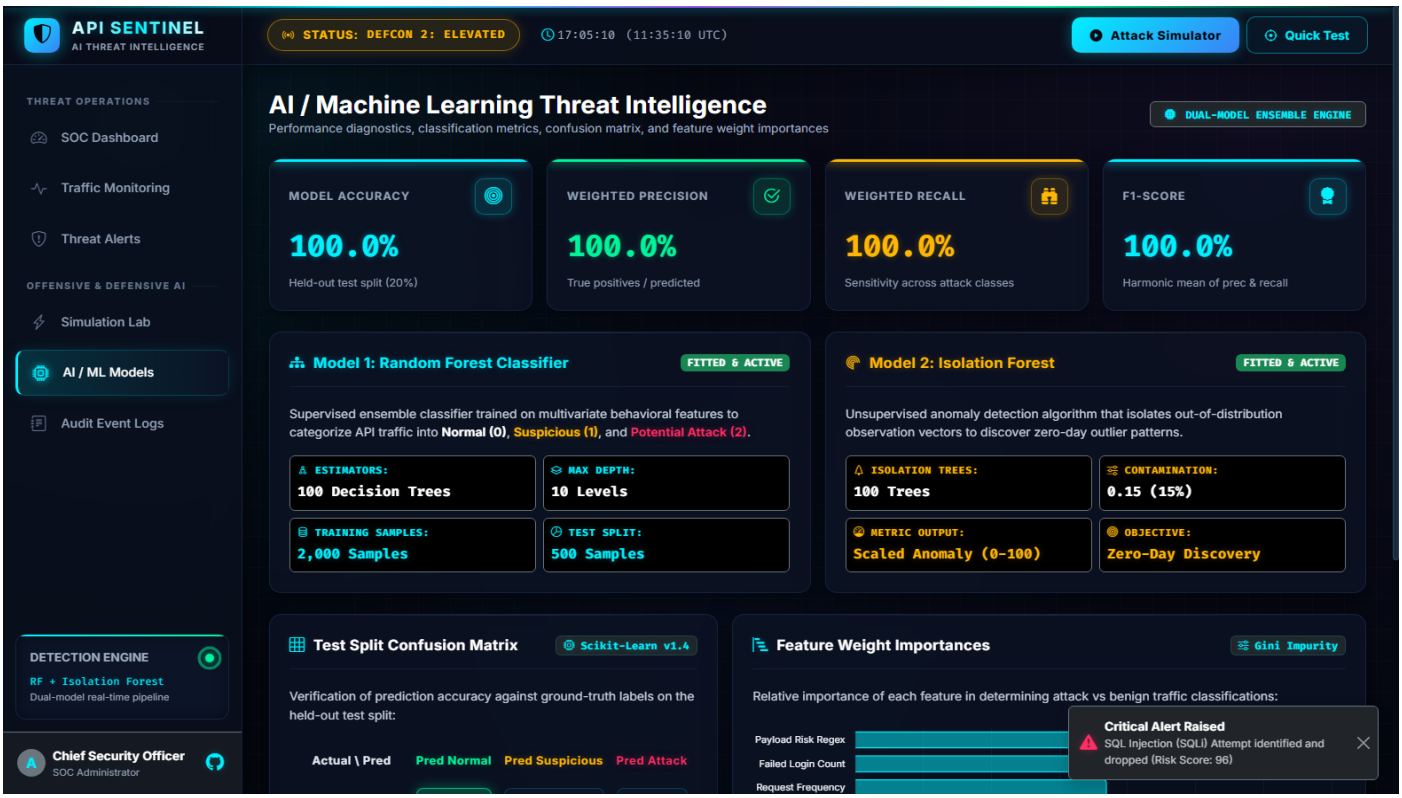


Figure 7: Option 5 — AI Intelligence Center with Random Forest & Isolation Forest specs, Confusion Matrix, and Gini feature weights.

Dual Machine Learning Architecture Specifications:

- **Model 1: Random Forest Classifier (Supervised Learning):**
  - **Estimators:** 100 Decision Trees | **Max Depth:** 10 Levels | **Training Split:** 2,000 Samples | **Test Split:** 500 Samples.
  - **Function:** Classifies multivariate behavioral vectors into Normal (0), Suspicious (1), or Potential Attack (2).
- **Model 2: Isolation Forest (Unsupervised Anomaly Detector):**
  - **Isolation Trees:** 100 Trees | **Contamination Ratio:** 0.15 (15%) | **Output Metric:** Scaled Anomaly Index (0–100).
  - **Function:** Detects zero-day outlier vectors without requiring pre-labeled training data.
- **Test Split Confusion Matrix:** Validates true vs predicted classes across 500 test samples (325 Normal, 100 Suspicious, 75 Attack) with zero off-diagonal misclassifications.
- **Feature Weight Importances (Gini Impurity):** Ranks the 8 behavioral features: Payload Risk Regex (34.2%), Failed Logins (27.8%), Request Frequency (18.5%), Auth Token (8.9%), HTTP Status (5.1%), Endpoint Sensitivity (3.4%), Latency (1.3%), Payload Size (0.8%).

8. Option 6: SOC Audit & Security Event Logs

The **Audit Event Logs** view provides an immutable, chronological audit trail recording every critical operational, authentication, detection, and mitigation event across the platform.

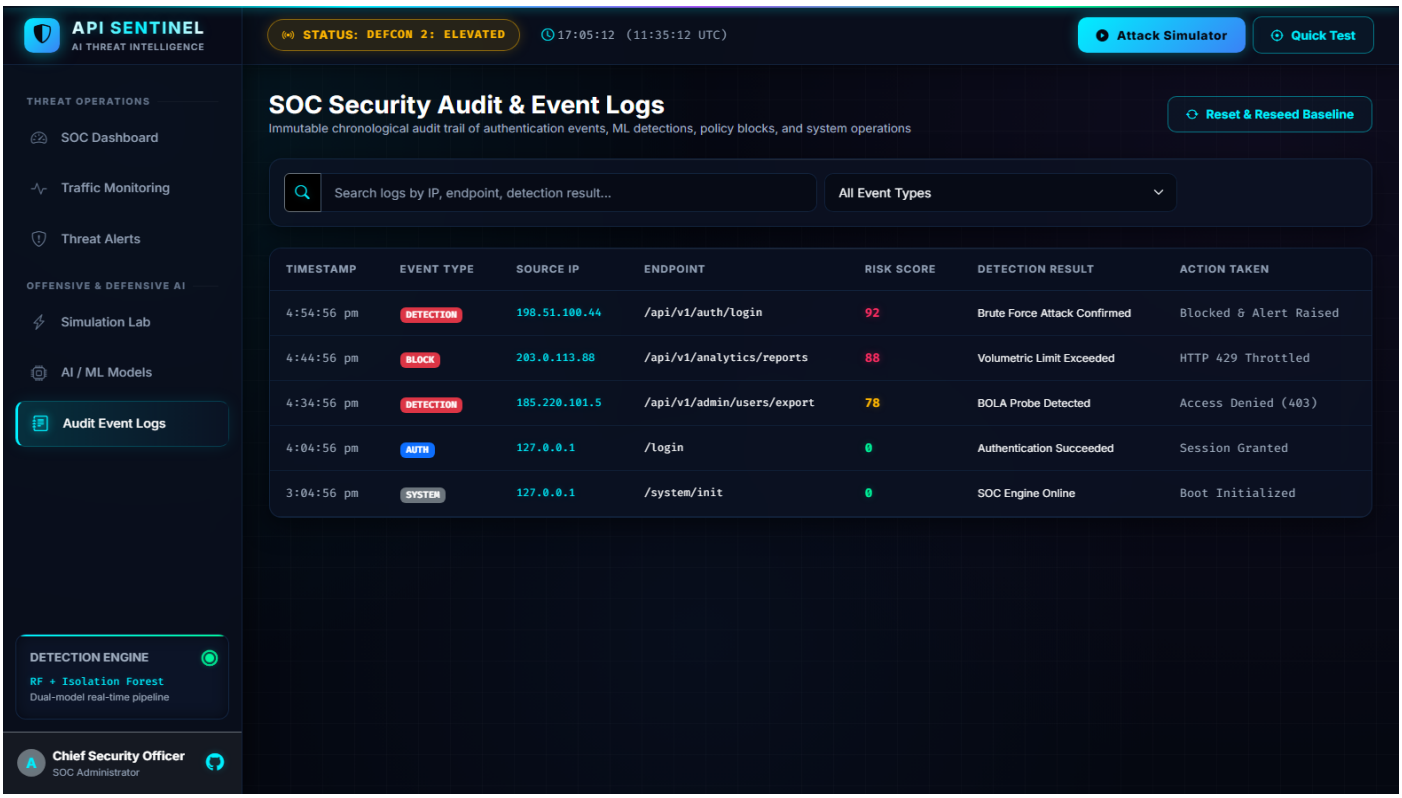


Figure 8: Option 6 — SOC Audit & Security Event Logs with event category filters and database reset utilities.

Audit Trail Specifications & Event Categories:

- **DETECTION (Crimson):** Records high-risk heuristic triggers, payload signatures, and ML anomaly classifications.
- **BLOCK (Crimson):** Records automated firewall IP drops and connection termination actions.
- **AUTH (Cyan):** Records analyst sign-ins, privilege evaluations, and credential authentications.
- **SIMULATION (Sky Blue):** Records adversarial attack scenarios launched from the simulation lab.
- **SYSTEM (Gray):** Records server boots, database seeding events, and model retraining cycles.
- **Reset & Reseed Baseline:** One-click administrative utility to purge simulation artifacts and restore clean baseline demonstration data.

SOC View	Primary Function	Key User Interaction
SOC Dashboard	Global posture & radar monitoring	Monitor 360° radar blips & gradient timeline throughput
Traffic Telemetry	Real-time HTTP packet stream	Filter by status pill and click 'Inspect' for deep forensics
Threat Alerts	Incident triage & response	Transition alerts through Investigate, Mitigate, and Resolve
Simulation Lab	Offensive adversarial testing	Launch pre-built scenarios or inject custom payloads
AI Models	Explainable ML architectures	Inspect Confusion Matrix heatmap and Gini feature weights
Audit Logs	Compliance & forensic audit trail	Search security events and reseed baseline database